

9

Chapter 9 – Database Security

With the development of information technology organizations have accumulated a huge volume of data regarding many aspects of their activities. All this data can be the basis for critical decisions, which means that data has become an extremely valuable resource for organizations, so it is necessary to pay close attention to data security. For these reasons, everyone in an organization must be sensitive to security threats and take measures to protect the data within their domains.

Our discussion in this chapter will be on the need for database security, concepts underlying access control and security in a database management system and different aspects regarding security policies and procedures.

9.1 Database security: The big picture

Often the problems related to security are complex and may involve legal, social or ethical aspects, or issues related to policies implemented or related to control of the physical equipment. Database security relates to protecting the database against intentional or unintentional threats, using elements of control that may or may not be based on the computing equipment.

The analysis of database security includes not only services provided by a DBMS, but a wider range of issues associated with database and the environment security.

Furthermore, security considerations not only apply to data contained in the database, because the gaps of security can affect other parts of the system, which in turn may affect the database.

In consequence, by focusing on database security alone will not ensure a secure database. All parts of the system must be secure: the database, the network, the operating system, the building in which the database resides physically and the persons who have an opportunity to access the system.

Figure 9.1 illustrates the big picture of database security.

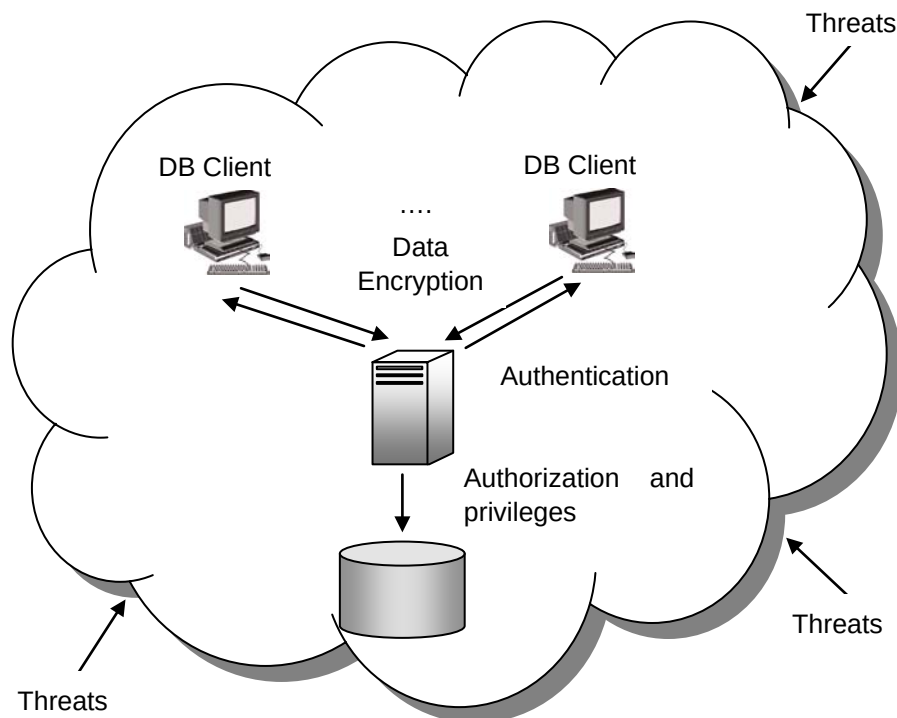


Figure 9.1 – Database security big picture

Designing and implementing a secure database involves achieving the following objectives:

- Privacy, which means that data should not be known by unauthorized users;
- Integrity, which means that only authorized users can change data;
- Availability, which means that authorized users should not be denied access;

To achieve these objectives, a clear security policy must be developed that describes measures to be imposed. In particular, it must be determined which users can access the database, and to which data they can access. Moreover, we must specify which operations can be run on the data.

Then we will call upon the security mechanism provided by the DBMS or the operating system. Any external mechanism, such as securing access to the building or room where the database physically resides, is beyond the scope of this discussion. The person responsible for the security of a database is the database administrator (DBA), who needs to take into account the various threats to the system.

The DBA defines the authorization rules that determine who can access the database, what parts of it can be accessed by each user, and which operations are allowed.

9.1.1 The need for database security

The reason that database security has become such an important issue is because of the increasing quantities of crucially important data that is collected and stored on computers.

Everyone recognizes that any loss of availability or loss of data could be potentially disastrous. A database is an essential collective resource which must be adequately insured, using appropriate control elements.

Threats on data security may be any situation or event, intentional or unintentional, which will negatively affect a system and finally an organization. The damage caused can be tangible (loss of data) or intangible (loss of credibility or trust of a client). Any threat should be viewed as a potential breach in the security system, which if successful, will have an impact on the organization.

Some examples of potential threats that may occur include:

- data use by a user having disk media access
- collection or unauthorized copying of data
- alteration of programs
- illegal access by a hacker
- theft of data, programs or equipment
- inadequate training of staff
- unauthorized disclosures of data
- calamities (fires, floods, bombings)
- breaking or disconnecting cables
- viruses

How much the organization suffers as a result of threat materialization depends on several factors, such as the existence of security measures and plans for exceptional circumstances.

For example, if a hardware failure occurs that alters the capacity of secondary storage, all the processing activities must cease until the problem is resolved. The period of inactivity and the speed with which the database is restored, will depend on the ability to use alternative elements of hardware and software; when the last backup was executed; the time required to restore the system; and the possibility that lost data cannot be restored and recovered.

It is necessary for organizations to identify the types of threats that they may be exposed to and initiate plans and appropriate measures, taking into account the cost of their implementation.

Spending a considerable amount of time, effort and money on some potential threats that would only result in some minor inconveniences may prove ineffective, economically. Business could influence, in turn, the types of threats to be considered, some of which might have very rare occurrences. However, rare events should be considered especially if their impact would be significant.

No matter how secure a computing system may seem to be, adequate data security can only be achieved if the environment is also secure.

The following threats must be addressed in any complete data security plan:

- Theft and fraud. These actions may be perpetrated by people and may or may not alter data. In this case, attention should focus on each possible location where data or applications reside physically. Concrete physical security must be established so that unauthorized persons are unable to gain access to rooms where computers, servers, or computer files are located. Using a firewall to protect unauthorized access to inappropriate parts of the database through outside communication links, is a procedure that will stop people who are intent on theft or fraud.
- Loss of privacy or confidentiality. Confidentiality refers to the need to preserve the secrecy of data. This is of major importance for the organization, and the privacy concerns need to protect data about individuals. Loss of privacy may lead to loss of competitiveness and failure to control privacy may lead to blackmail, bribery, public embarrassment, or stealing of user passwords. Some of these may lead to legal measures against the organization.
- Loss of data integrity. If data integrity is impacted, data will be invalid or corrupted. In this case, an organization may suffer important losses or make wrong decisions based on incorrect data.
- Loss of availability. This means that the data, the system, or both, cannot be accessed. Sometimes this phenomenon is accompanied by alteration of data and may lead to severe operational difficulties. This may arise as a result of sabotage of hardware, network or application, or as a result of introducing viruses.
- Accidental losses of data. This may be the result of a human error, or software and hardware breaches. To avoid accidental loss of data, an organization should establish clear procedures for user authorization, uniform software installation, and hardware maintenance. As in any action that involves human beings, some losses are inevitable, but it is desirable that the used policies and procedures will lead to minimal loss.

Database security aims to minimize losses caused by the events listed above in an efficient way in terms of cost, and without undue constraints on users. Since computer-based crime is booming and this type of crime can threaten all the components of a system, appropriate security measures are vital.

The most used measures to ensure protection and integrity of data include: access control, views, integrity controls and encryption. It is also necessary to establish appropriate security policies and procedures, which refer to personnel and physical access control.

9.1.2 Access control

In practice, there are two major approaches to data security. These are known as **discretionary control** and **mandatory control**. In both cases, the unit of data or data object to be protected can vary from the entire database to one or more records. By

discretionary control, a user will have different access rights, also known as privileges on individual items. Obviously, there are various limitations in terms of rights that different users have on various objects.

For example, in a system for which the discretionary control is used, a user may be able to access object X of the database, but cannot access object Y, while user B can access object Y, but cannot access object X.

Discretionary control schemes are very flexible. You can combine rights and assign to users and objects according to your needs.

In the case of mandatory control, each data object is associated with a certain classification level and each user is given a certain permission level. A given data object can then be accessed only by users with the appropriate permission. Mandatory schemes are hierarchic in nature and are hence more rigid than discretionary ones.

Regardless of the type of security scheme that is used, all decisions on the rights that various users have regarding the database objects are business decisions not technical ones.

In order to decide what security constraints are applicable to a request for access, the system must be able to recognize the source of the request. In other words, it must recognize the user that launched the application and it must verify the user's rights.

9.1.3 Database security case study

In this section we analyze how DB2, IBM's leading data server solves these security problems with its own security mechanisms. Security mechanisms for DB2 contain two main operations: authentication and authorization, which are running together in order to ensure security of access to DB2 resources.

9.1.3.1. Authentication

Authentication is the first action performed to successfully connect to a DB2 database. Authentication is the process by which users are identified by the DBMS and prove their identity to access the database.

User and group identity validation is achieved through security facilities located outside of the DBMS that is, they are performed as part of the operating system or using a third-party security facility, such as Kerberos or Lightweight Directory Access Protocol (LDAP). Authentication of a user requires two elements: a user ID and an authentication token.

The user ID allows the security component to identify the user and by supplying the correct authentication token (a password known only by the user and the security component), the user identity is verified. Sometimes if greater flexibility is needed you can build custom security plug-in modules for DB2 to use.

After successful authentication of a user, the authenticated user ID is mapped to an authorization ID. This mapping is determined by the authentication security plug-in. If the default IBM shipped authentication security plug-in is used, there are two derived authorization IDs provided: system and session IDs. In this case both authorization IDs are

derived in the same way from the user ID and are identical. The system authorization ID is used for checking the connect privilege to establish a connection. The session authorization ID is the primary ID for the next connection.

9.1.3.2. Authorization

After a user is authenticated, it is necessary to determine whether that user is authorized to access certain data or resources. Authorization is the process of granting privileges, which allows a subject to have legitimate access to a system or an object in a system. The definition of authorization contains the terms subject and object. The subject refers to a user or program and the term object addresses a table, a view, an application, procedure or any other object that can be created in the system.

Authorization control can be implemented by software elements and it can regulate both systems and objects to which a user has access and what a user can do with them. For this reason, the authorization is also called access control. For example, a user may be authorized to read records in a database, but cannot modify or insert a record.

Authorization rules are controls incorporated in the DBMS that restrict the action that user may take when they access data. DB2 tables and configuration files are used to record the permissions associated with each authorization name.

When an authenticated user tries to access data, the authorization name of the user and the set of privileges granted to them, directly or indirectly through a group or a role, are compared with the recorded permissions. The result of the compare is used to decide whether to allow or reject the requested access.

For an authorization ID, there are more sources of permissions. Firstly, there are the permissions granted to the authorization ID directly. Then there are those granted to the groups and/or roles in which the authorization ID is member. Public permissions are those granted to a PUBLIC group, while context-sensitive permissions are those granted to a trusted context role.

In order to perform different tasks, the DBMS requires that each user be specifically, implicitly, or explicitly authorized. Explicit privileges are granted to a user, a group or a role, whereas implicit privileges are those acquired through groups to which the user belongs or through the roles assigned.

DB2 works with three forms of recorded authorization: administrative authority, privileges, and Label-Based Access Control (LBAC) credentials. A user, a group or a role can have one or more of these authorizations.

9.1.3.3 Administrative Authority

Administrative authority confers to a person the right to control the database and have the responsibility for data integrity. DB2 administrative authority is hierarchical. On the highest level there is SYSADM. Under SYSADM there are two kinds of authorities: instance level and database level. The levels of authority provide a method of grouping different privileges.

DB2 instance authority applies to all databases within the instance and is associated with group membership. The group names that are associated with this authority level are stored in the database manager configuration files for a given instance.

At this level there are four DB2 instance authorities:

- **SYSADM** (system administrator) authority level controls all the resources created and maintained by the database manager. Users with SYSADM authority can perform the following tasks: migrate databases, modify the database manager configuration and database configuration files, perform database and log file backups and restoration of database and database objects such as table spaces, grant and revoke other authorities and privileges to and from users, groups or roles, full control of instances and manage audit on the instance level.
- **SYSCTRL** (system control) authority provides control over operations that affect system resources. A user with SYSCTRL authority can create, update start, and stop a database. It can also start and stop an instance, but cannot access data from tables.
- **SYSMAINT** (system maintenance) is an authority level which allows performing maintenance operations on all databases associated with an instance. These operations refer to update the database configuration, backup a database or a table space, restore an existing database or monitor a database. SYSMAINT does not allow access to data.
- **SYSMON** (system monitor) may operate at the instance level. Concretely, it provides the authority required to use the database system monitor.

DB2 database authorities refer to a specific database within the DB2 instance. These include:

- **DBADM** (database administrator) which applies at the database level and provides administrative authority over a single database. A database administrator has all the privileges to create objects, execute database commands, and access all data. He can also grant and revoke individual privileges. A database administrator can create log files, query system catalog tables, update log history files, reorganize database tables or collect catalog statistics.
- **SECADM** (security administrator) has the authority to create, drop, grant and revoke authorization or privileges, and transfer ownership of security objects (e.g. roles and LBAC labels). It has no privileges to access data from tables.
- **CONNECT** allows the user to connect to the database.
- **BINDADD** enables the user to create new packages in the database.
- **CREATETAB** allows the user to create new tables in the database.
- **CREATE_EXTERNAL_ROUTINE** permits the user to create a procedure for use by applications and other users of the database.

- `CREATE_NOT_FENCED_ROUTINE` allows the user to create a user-defined function (UDF) or procedure that is not fenced.
- `IMPLICIT_SCHEMA` permits any user to create a schema by creating an object by `CREATE` statement with a schema name that does not already exist. In this case, SYSIBM becomes the owner of the implicitly created schema and PUBLIC has the privilege to create objects in this schema.

9.1.3.4 Privileges

Privileges are authorities assigned to users, groups or roles, which allow them to accomplish different activities on database objects. *Figure 9.2*, presents some DB2 privileges [9.1].

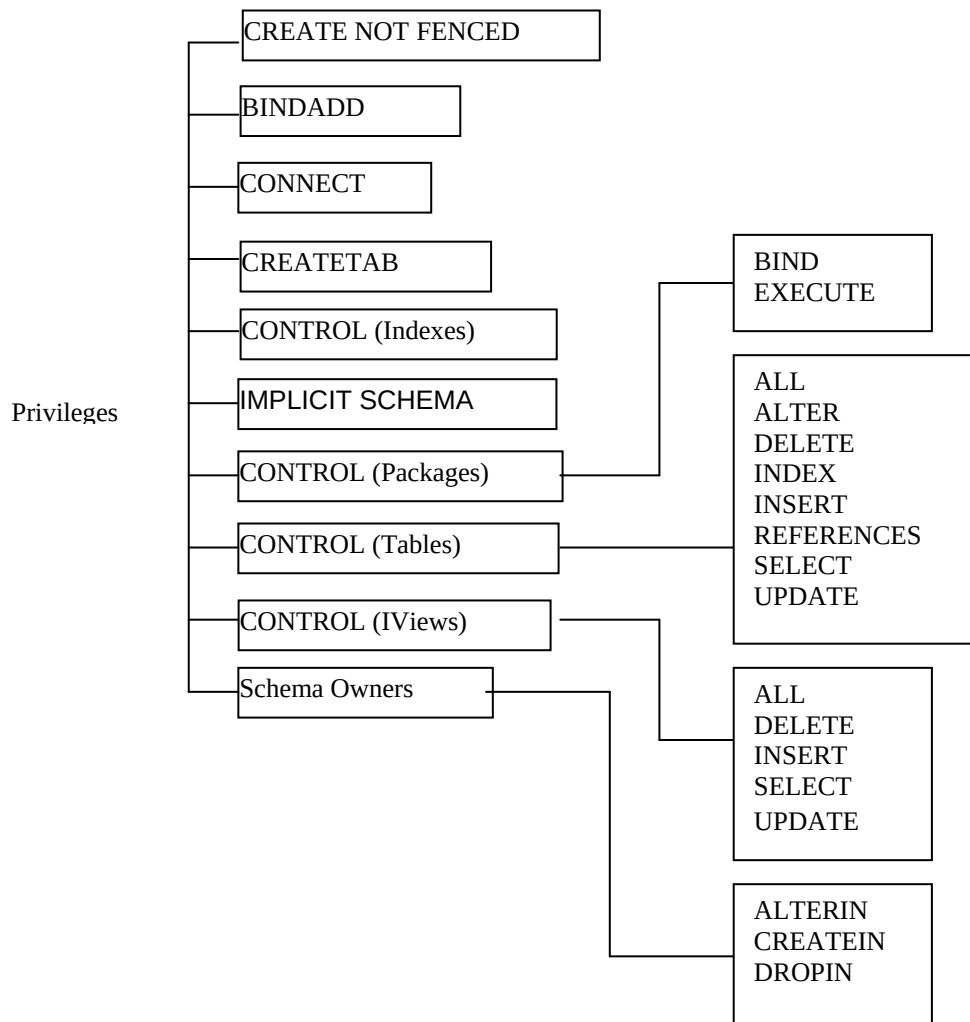


Figure 9.2 - List of some DB2 privileges

Privileges define the tasks user can perform on database objects and can be granted to individual users, groups, roles or PUBLIC.

PUBLIC is a special group, for which certain database authorities and privileges can be granted to and revoked from. This can be done by any user who successfully authenticates with the DB2 instance. After a database is created the following database privileges are granted to PUBLIC by default: CONNECT, CREATETAB, BINDADD, IMPLICIT_SCHEMA, SELECT, UPDATE, EXECUTE, USE.

Users or groups who receive CONTROL privileges can also grant the privilege to some others users or groups.

9.1.3.5 Label Based Access Control

Label Based Access Control (LBAC) is a flexible implementation of mandatory access control (MAC). LBAC acts at both the row level and the column level and complete the discretionary access control (DAC).

The two levels of protection can be used separately or combined. LBAC can be configured to meet the security needs of each environment. All configurations are performed by a security administrator by creating security policies which describe the criteria that will be used to decide who has access to what data.

Once a security policy is established, the security administrator can create objects called security labels as part of this policy. After a security label is created it can be associated with individual columns and rows in a table to protect its data. Data protected by a security label is called protected data. A security administrator allows users access to protected data by granting them security labels. When a user tries to access protected data, their security label is compared to the security label protecting the data. It is the way to determine whether the user is allowed access to data at the column level, row level or both, or denies access to the data. A security administrator can also grant exemptions to users in order to allow the access to protected data that the security labels might otherwise prevent from access. The security labels and exemptions are LBAC credentials and are stored in the database catalogs.

The main advantage of using LBAC to protect important data is that no authority (SYSDBA, DBADM, and SECADM) has any inherent privileges to access your data.

9.1.3.6 Roles

In practice there are situations where multiple users must have the same set of privileges. In this case it is better to manage this set as a whole rather than handle each privilege separately, so it is appropriate to work with roles.

A database role is an object that groups together one or more privileges or database authorities. It can be assigned to users, groups, PUBLIC or other roles by a GRANT statement. For example, we can define a developer role and allow this role to insert, update and delete data on a set of tables.

By associating a role with a user, the user inherits all the privileges held by the role, in addition to privileges already held by the user.

A role may control database access at a level of abstraction that is proper to the structure of the organization, because one can create roles that map directly to those in the

organization. In this case users are granted membership to the roles based on their job responsibilities. When the user's responsibilities change within the organization, the user membership in roles can easily be granted and revoked. Roles can be updated without updating the privileges for every user. Roles are managed inside the database and DB2 can determine when an authorization changes and act accordingly.

9.1.3.7 Trusted Contexts

In a three-tiered application model, where there is a Web server, an application server, and a database server; the middle tier or application server is responsible for authenticating the users running the client applications and managing the interactions with the database server. The application's server authorization ID needs to have all the privileges associated with end-users in order to perform any operations that the end users may require. While the three-tiered application model has many benefits, having all interactions with the database server (such as a user request) occur under the application server's authorization ID. This raises several security concerns like not being able to determine which client user ID performed a query at fault, for example.

Trusted contexts establish a trusted relationship between DB2 and an external entity like an application server or another DB2 server. This trust relationship is based upon the following attributes: system authorization, IP address or domain name and data stream encryption.

After a database connection has been established the attributes of that connection are compared with the definition of each trusted context object in the database. If these attributes match the definition of a trusted context object then the connection is referred to as a trusted connection. This kind of connection allows its initiator to acquire additional capabilities that are not available to them outside the scope of that trusted connection.

One may deal with two types of trusted connections: explicit or implicit. An explicit trusted connection is a trusted connection that is explicitly requested and it allows the initiator the ability to switch the current user ID on the connection to a different user ID, with or without authentication, and to acquire additional privileges that may not be available to them outside the scope of the trusted connection.

An implicit trusted connection is a trusted connection that is not explicitly requested and it allows only the ability to acquire additional privileges.

In order to define a trusted connection the following attributes must be defined:

- a system authorization ID which is the authorization ID that must be used by an incoming connection to be trusted
- a list of IP addresses representing the IP addresses from which an incoming connection must originate in order to be trusted
- a data stream encryption representing the level of encryption that must be used by an incoming connection in order to be trusted

9.1.4 Views

In conjunction with the authorization process, views are an important component of the security mechanism provided by a relational DBMS. Views allow a user to see information while hiding any information that the user should not be given access to.

A view is the dynamic result of one or more relational operations that apply to one or more base tables to produce another table. A view is always based on the current data in the base tables from which it is built.

The advantage of a view is that it can be built to present only the data to which the user requires access and prevent the viewing of other data that may be private or confidential.

A user may be granted the right to access the view but not to access the base tables upon which the view is based.

9.1.5 Integrity Control

The aim of integrity control is to protect data from unauthorized use and update, by restricting the values that may be held and the operations that can be performed on data. Integrity controls may also trigger the execution of some procedure, such as placing an entry in a log that records what users have done what with which data. There are more forms of integrity controls.

The first form that we discuss is the integrity of the domain. A domain may be viewed like a way to create a user-defined data type. Once a domain is created it may be assigned to any field as its data type. Consequently any value inserted in the field must belong to the domain assigned. When a domain is created, it may use constraints (for example a CHECK constraint) to restrict the values to those which satisfy the imposed condition. An important advantage of a domain is that if it must change then it can be modified in a single place – the domain definition.

Assertions are also powerful constraints that enforce some desirable database conditions. They are checked automatically by the DBMS when transactions are run involving tables or fields on which assertion exists. If the assertion fails, the DBMS will generate an error message.

For security purposes one can use triggers as well. Triggers consist of blocks of procedural code that are stored in a database and which run only in response to an INSERT, UPDATE or DELETE command. A trigger, which includes an event, condition, and action, may be more complex than an assertion. It may prohibit inappropriate actions, it may cause special handling procedures to be executed, or it may cause a row to be written to a log file in order to store important information about the user and transactions made to sensitive data.

9.1.6 Data encryption

Sensitive and personal data stored within the database tables and critical data transmitted across the network, such as user credentials (user ID and password), are vulnerable and should be protected against intruders.

Encryption is the process of encoding data by a particular algorithm, which makes it impossible for a program to read data without the decryption key. Usually encryption protects data transmitted through communication lines. There are more techniques for encoding data, some of which are reversible, while others are irreversible. Irreversible techniques do not allow knowledge of the original data, but can be used to obtain valid statistical information.

Any system that provides encryption facilities must also provide adequate routines for decoding, routines which must be protected by proper security.

9.2 Security policies and procedures

It is mandatory to establish a set of administrative policies and procedures in order to create a context for effectively implementing security measures. There are two types of security policies and procedures: personnel controls and physical access controls.

9.2.1 Personnel control

Often the greatest threat to data security is internal rather than external, so adequate controls of personnel must be developed and followed. The security authorization and authentication procedures must be enforced by procedures which ensure a selection hiring process that validate potential employees regarding their backgrounds and capabilities. Employees should be trained in those aspects of security that are relevant to their jobs and encouraged to be aware of and follow standard security measures. If an employee should need to be let go then there should be a set of procedures to remove authorizations and authentications and to notify other employees about the status change.

9.2.2 Physical access control

An important physical access control is related to limiting access to particular areas within a building. A proximity access card can be used to gain access to a secured area. In this case, each access can be recorded in a database. When it is necessary a guest should be issued badges and escorted in these areas.

Sensitive equipment can be controlled by placement in a secure area. Other equipment can be locked in a desk or have an alarm attached. Backup data media should be kept in fireproof data safe or kept outside in a safe location. Procedures must explicitly state a schedule for moving media or disposing of media, and establish labeling and indexing of such materials stored.

Lately, new companies are trending towards an increasingly mobile nature of work. Laptops are very susceptible to theft, which puts data on the laptop at risk. Encryption and multiple factor authentication can protect data. Antitheft devices, like security cables or geographical tracking chips, can help determine theft and quickly recover laptops on which critical data are stored.

9.3 Summary

This chapter covered the general security aspects of databases.

The chapter started describing the need to protect data and their environment, and the different threats can affect data in databases and the whole organization.

The first security measure refers to access control, which may be discretionary or mandatory. We presented various cases of access control that can be implemented in DB2, such as authentication and authorization mechanism, privileges, roles, label based access control and trusted contexts.

A simple and flexible way to hide a big part of a database from users is by utilizing views.

Integrity control aims to protect data from unauthorized access, by restricting the values that may be assigned and the operations that can be performed on data. For these purposes, there are defined domains, assertions and triggers.

Critical data transmitted across the network and personal and sensitive data must be protected by encryption.

The measures mentioned in this chapter may not stop all malicious or accidental access or modification of data. For this purpose it is necessary to establish a set of administrative policies and procedures in order to create a context for effectively implementing these measures. The most used procedures and security policies refer to personnel control and physical access control.

9.4 Exercises

Review Chapter 10, "Database security" in the free eBook [Getting started with DB2 Express-C](#) and create two users in your operating system.

Can those two users create a database? Why?

Can the two users connect to the database? Why?

Can the two users select from the view SYSCAT.TABLES? Why?

9.5 Review Questions

1. Why is it necessary to protect data in a database?
2. Is it enough to protect only data in a database?
3. What are some threats that must be addressed in a complete security plan?
4. What is the definition of the discretionary control of access?
5. What are the forms of authorization in DB2?
6. What are privileges?
7. How are trusted contexts used in DB2?

-
8. What is a view and why is that considered an important component of the security mechanism?
 9. How can integrity control be assured?
 10. What are the most used security policies and procedures?